



Task – 1: Vulnerability Assessment and Penetration Testing (VAPT)

Theoretical Knowledge

1. Understanding Security Assessment

Objective

Learn how to evaluate systems without paid tools.

Explanation

Security Assessment is the process of identifying weaknesses in systems, networks, and applications.

It is performed using recognized frameworks such as **NIST guidelines** to understand security gaps and improve protection without relying on paid tools.



Types of Security Testing

Vulnerability Assessment

Vulnerability Assessment is used to identify known security weaknesses in systems.

Open-source tools such as **OpenVAS** are used as vulnerability scanners to detect outdated software, missing patches, and known vulnerabilities.

Penetration Testing

Penetration Testing simulates real-world attacks to evaluate system security.

Tools available in **Kali Linux**, such as **Metasploit** and **Nmap**, are used to simulate attack scenarios.

Compliance Testing

Compliance Testing is used to validate systems against security standards. This is done using checklists and benchmarks such as **CIS Benchmarks**.

2. VAPT Methodology

Objective

Follow a structured approach using methodologies.



Explanation

VAPT methodology provides a systematic process to perform security testing in an organized manner.

Phases

Planning

In this phase, the scope of the assessment is defined.

Tools such as **Dradis CE** are used to manage scope and documentation.

Discovery

The discovery phase focuses on identifying systems, services, and applications.

Nmap is used for network scanning and **OWASP ZAP** is used for web application scanning.

Attack

In this phase, vulnerabilities are tested to understand their impact.

The **Metasploit Framework** is used to exploit vulnerabilities in a controlled environment.

Reporting

All findings are documented in a structured format.

Report templates from **Pentest-Tools** are used for professional reporting.



3. Security Standards & Compliance

Objective

Align with regulations using resources.

Explanation

Security standards help ensure proper protection of sensitive data and systems.

Standards

- **GDPR**
- **HIPAA**
- **ISO 27001**

4. Risk Assessment Basics

Objective

Prioritize vulnerabilities with scoring systems.

Explanation

CVSS Calculator

The **NVD CVSS Calculator** is used to calculate vulnerability severity scores.

Risk Matrix



Risks are categorized as **High, Medium, or Low** using spreadsheets such as **Google Sheets or Excel**

5. Common Vulnerabilities

Objective

Identify flaws in labs and tools.

Explanation

Network Vulnerabilities

Network vulnerabilities include misconfigurations and open ports. These are identified using **Nmap**.

Web Vulnerabilities

Web vulnerabilities include **SQL Injection (SQLi)** and **Cross-Site Scripting (XSS)**. Practice is done using **OWASP Juice Shop**.

How to Learn

Use labs to understand the practical approach:

- **Metasploitable** (intentionally vulnerable VM)
- **VulnHub** (vulnerable machines)



6. Documentation Fundamentals

Objective

Create reports with tools.

Explanation

Tools

- **Dradis CE** (collaborative reporting)
- **CherryTree** (note-taking for technical findings)
- Any standard reporting tool can also be used

How to Learn

Use free templates available on **GitHub**.

Practical Application

1. Setup Testing Environment

Steps

- Install **Kali Linux**
 - Download **Metasploitable 3** (vulnerable VM) from GitHub
 - Configure **VirtualBox** to host virtual machines
-



2. Vulnerability Scanning

Tools

- **OpenVAS** (integrated in Kali Linux)
- **Nikto** (web server scanner)

Steps

- Scan Metasploitable using OpenVAS
sudo openvas-start
- Analyze results such as **CVSS scores** and **CVE IDs**

3. Document Findings

Tools

- **Google Sheets / Excel** for vulnerability tracking
- Screenshots

Steps

- Record IP addresses, ports, and services
- Document vulnerability descriptions (e.g., *Apache Tomcat outdated*)

4. Practice Risk Assessment

Steps

- Use the **CVSS Calculator** to score vulnerabilities
- Prioritize risks using a **3x3 matrix (Likelihood vs Impact)**

5. Create Basic Reports

Steps

- Summarize sources consulted for each topic
- Submit a **comprehensive report as a PDF file**

Report Structure

- **Executive Summary** – High-level risks
- **Technical Details** – Screenshots and CVSS scores
- **Remediation** – Patch links and configuration fixes